

## Task 5 Cyber-Risk Escalation and Segregation of Duties (20 marks)

### Risk Escalation Threshold

| Level                      | Example Trigger                                                                                                                               | Decision Authority                                              | Required Notification                                           | Target Response Time                 |
|----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------|-----------------------------------------------------------------|--------------------------------------|
| Level 1 – Operational      | Low-impact vulnerabilities, routine security issues, minor control failures with limited business impact                                      | IT Managers, Security Operations, Business Owners               | Relevant operational teams and Security Governance Team         | Within 5 business days               |
| Level 2 – Executive        | Significant vulnerabilities, repeated control failures, security exceptions, risks requiring additional funding or cross-functional decisions | CISO, Security Governance Committee, Executive Security Council | CEO, CRO, Legal                                                 | Within 48 hours                      |
| Level 3 – Material / Board | Major cyber incidents, regulatory exposure, significant financial impact, customer data compromise, risks exceeding organisational appetite   | CEO, Executive Security Council, Board Risk Committee           | Board, Legal, Regulators (where required), Executive Leadership | Immediate escalation within 24 hours |

### Cyber-risk escalation workflow

